Sare Segurtasuna

Mikel Egaña Aranguren

mikel-egana-aranguren.github.io

mikel.egana@ehu.eus

Universidad del País Vasco
Euskal Herriko Unibertsitatea
BILBOKO INGENIARITZA ESKOLA
ESCUELA DE INGENIERÍA DE BILBAO

Sare Segurtasuna

https://doi.org/10.5281/zenodo.4302267

https://github.com/mikel-egana-aranguren/EHU-issks-31



OSI (Open Systems Interconnection)

Layer			Protocol data unit (PDU)	Function[27]
Host layers	7	Application	Data	High-level protocols such as for resource sharing or remote file access, e.g. HTTP.
	6	Presentation		Translation of data between a networking service and an application; including character encoding, data compression and encryption/decryption
	5	Session		Managing communication sessions, i.e., continuous exchange of information in the form of multiple back-and-forth transmissions between two nodes
	4	Transport	Segment	Reliable transmission of data segments between points on a network, including segmentation, acknowledgement and multiplexing
Media layers	3	Network	Packet, Datagram[28]	Structuring and managing a multi-node network, including addressing, routing and traffic control
	2	Data link	Frame	Transmission of data frames between two nodes connected by a physical layer
	1	Physical	Bit, Symbol	Transmission and reception of raw bit streams over a physical medium

https://en.wikipedia.org/wiki/OSI_model

TCP/IP

<table>
<tr><th>OSI Model</th><th colspan="6">TCP/IP Protocol Suite</th></tr>
<tr><td>Application
Presentation
Session</td><td>File Transfer

FTP
TFTP</td><td>Web Browser

HTTP</td><td>Email

SMTP
IMAP
POP3</td><td>Remote Login

Telnet</td><td>Name Resolution

DNS</td><td>IP Address

DHCP</td></tr>
<tr><td>Transport</td><td colspan="3">Transmission Control Protocol
TCP</td><td colspan="3">User Datagram Protocol
UDP</td></tr>
<tr><td>Network</td><td colspan="3">Internet Protocol
IP</td><td colspan="3">ARP
ICMP</td></tr>
<tr><td>Data Link</td><td colspan="2">Ethernet</td><td>Token Ring</td><td>FDDI</td><td colspan="2">WAN Protocols</td></tr>
<tr><td>Physical</td><td colspan="6">Copper Twisted Pair
Fiber Optic
Wireless</td></tr>
</table>

https://www.cdebyte.com/news/889

CIDR (Classless Inter-Domain Routing)

IP helbideak esleitu eta bideratzea sareetan

Adibidea: 192.168.1.0/24

sarea: 192.168.1.0 - 192.168.1.255 / host edo azpisarea 192.168.1.1 - 192.168.1.254

Sare-maskara (router-ak sare batetik bestera): 255.255.255.0

Sare trafikoa lortzea

Wireshark laborategia

Sarearen segmentazioa

Segmentazio fisikoa

Segmentazio logikoa VLAN bidez (OSI 2. geruza): gailuak funtzionalitatearen arabera taldekatu

Segmentazio logikoa azpisareen bidez (OSI 3. geruza): sarea azpisare txikiagoetan banatzea (IP helbideen barrutia)

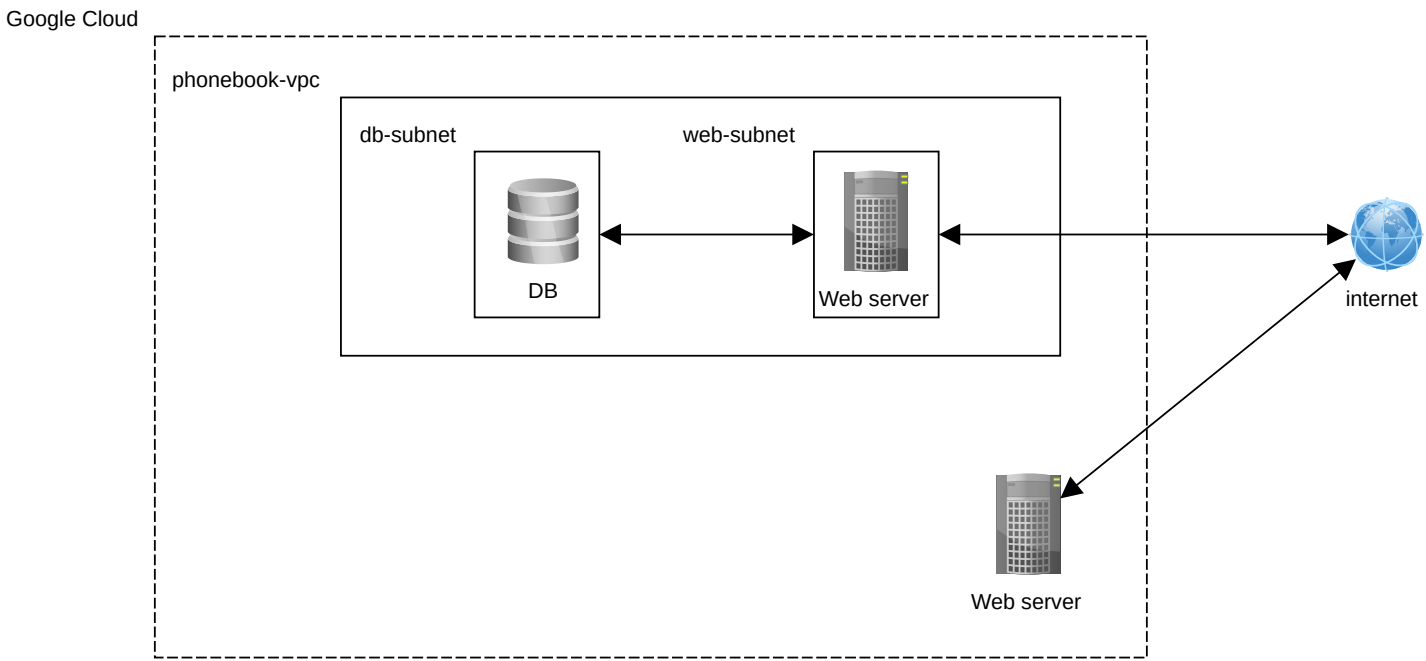
VPC (Virtual Private Cloud)

- Isolamendua: sarea logikoki beste bezero edo erabiltzaile batzuetatik bereizita dago
- IP kontrola: IP helbide-barrutiak, azpisareak eta bide-taulak hautatzea
- Gateways: Interneteko gateway-ak eta NAT-ek sarrerako eta irteerako trafikoa kontrolatzen dute

VPC Google Cloud

Firewall arauen helburuak tag-en bidez definitzen dira (adib. http-server, https-server) CIDR blokeen ordez

VPC Google Cloud



VPC Google Cloud

VPC Google Cloud Laborategia

Firewall

Aurrez definitutako arauen arabera sarearen sarrerako eta irteerako trafikoa kontrolatzen duen gailua/softwarea

Arauak segurtasun-irizpide desberdinetan oinarritzen dira

Firewall: funtzioak

Paketeen iragazketa: pakete bakoitza aztertu eta arauekin konparatzen du

Sarbide-kontrola: zerbitzu edo protokoloetarako sarbidea baimentzen edo ukatzen du

Erregistroa eta auditoretza

NAT (Network Address Translation): hainbat gailuk IP helbide publiko bakarra partekatzen dute

Firewall: motak

Packet Filtering Firewalls: Sareko paketeen goiburuak bakarrik aztertzen dituzte eta trafikoa baimentzen edo blokeatzen dute: jatorriko eta helmugako IPa, erabilitako portuak eta protokoloak

Stateful Inspection Firewalls: Paketeen goiburuak aztertzeaz gain, sareko konexioen egoeraren jarraipena egiten dute. Paketeen edukia azter dezakete eta konexioaren egoeran oinarritutako erabakiak hartu

Firewall: motak

Application Firewalls (Proxy Firewalls): Trafikoa aztertzen dute, aplikazio-protokolo zehatzak barne, hala nola HTTP, FTP edo SMTP. Mezuen edukia aztertzen dute eta segurtasun-arau aurreratuagoak aplikatzen dituzte aplikazioen mehatxu zehatzak detektatu eta blokeatzeko

Firewall: arau orokorrak

Difusio-helbidea (Broadcast) duten paketeak blokeatu, DoS erasoak saihesteko

Barne-helbideei dagozkien jatorrizko helbideak dituzten sarrerako paketeak blokeatu, nortasun-ordezkapena (Spoofing) saihesteko

Blokeatu RFC 1918 (Address Allocation for Private Internets) dokumentuan aipatutako helbide pribatuak dituzten sarrerako pakete guztiak

Firewall: arau orokorrak

127.0.0.1 jatorrizko helbide gisa duten sarrerako paketeak blokeatu

Ping edo Traceroute eskaerei erantzunez barne-sarearen topologiari buruzko informazioa eman dezaketen ICMP kontrol-protokoloko paketeak blokeatu

Firewall: arau orokorrak

Routerren bideratze-taulak aldatzeko aukera ematen duten ICMP Redirect paketeak blokeatu

Baimendutako gutxienekoa baino tamaina txikiagoa duten edo goiburuan balio baliogabeak dituzten pakete guztiak blokeatu

Firewall: blokeatu beharreko portuak

Urruneko konexioa: Telnet (23), SSH (22), FTP (21)

RPC (Remote Procedure Call) eta NFS (Network File System) zerbitzua UNIX sareetan

HTTP, SSL, SMTP, POP, IMAP, DNS, LDAP zerbitzari gisa aritzen ez diren makinetan

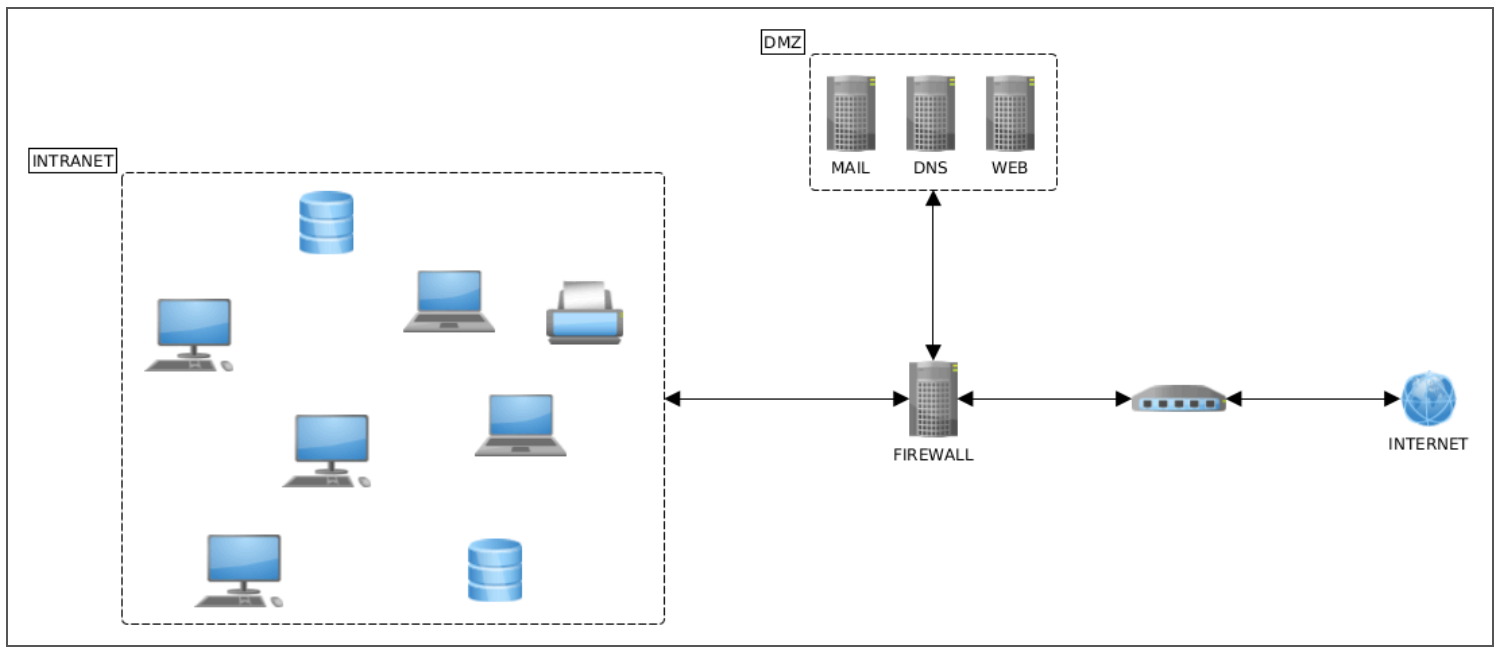
DMZ (Zona Desmilitarizatua)

Intranetaren eta Interneten arteko azpisarea, segurtasun-arazoen eraginpean gehien dauden zerbitzu publikoak (posta, ftp, etab.) kokatzen diren lekua

Firewall bat edo bi erabiliz sortzen da

DMZtik ezin da zuzenean intranetera sartu

DMZ



Firewall

Firewall laborategia

NMAP

NMAP laborategia

Load balancer

Sareko trafikoa zerbitzari batzuen artean banatzea zerbitzuen errendimendua eta erabilgarritasuna hobetzeko

Bezeroen eta zerbitzarien arteko bitartekaria

Aplikazio-maila (HTTP) edo garraio-maila (TCP/UDP)

Load balancer

Karga-banaketa

Akatsekiko tolerantzia

Eskalagarritasuna

Saioen kontrola

Errendimenduaren optimizazioa

Load balancer

Load balancer laborategia

Proxy

Bitartekari gisa jarduten duen aplikazioa

Bezeroak proxy-ari egiten dizkio eskaerak, eta honek kudeatu eta urruneko zerbitzariei bidaltzen dizkie

Segurtasun handiagoa ematen du nabigazioan, zerbitzariak ez baitaki nor konektatu den benetan

Zerbitzariaren erantzunak cache-an gordetzea

Proxy HTTP(S)

Webguneetarako sarbidea

Edukiaren iragazketa

Cache-an gordetzea

Proxy SOCKS

Garraio-mailako proxy-a

SOCKS protokoloaren bidezko konexioa ahalbidetzen du

Sareko trafikoaren bideratzea

Anonimotasuna

Reverse proxy

Zerbitzari aldea

Karga-banaketa

Azpiegituraren babesa

Reverse proxy

Reverse proxy laborategia (Squid)

IDS/IPS

IDS (Intrusion Detection System): intrusioak detektatzeko sistema

IPS (Intrusion Prevention System): intrusioak prebenitzeko sistema

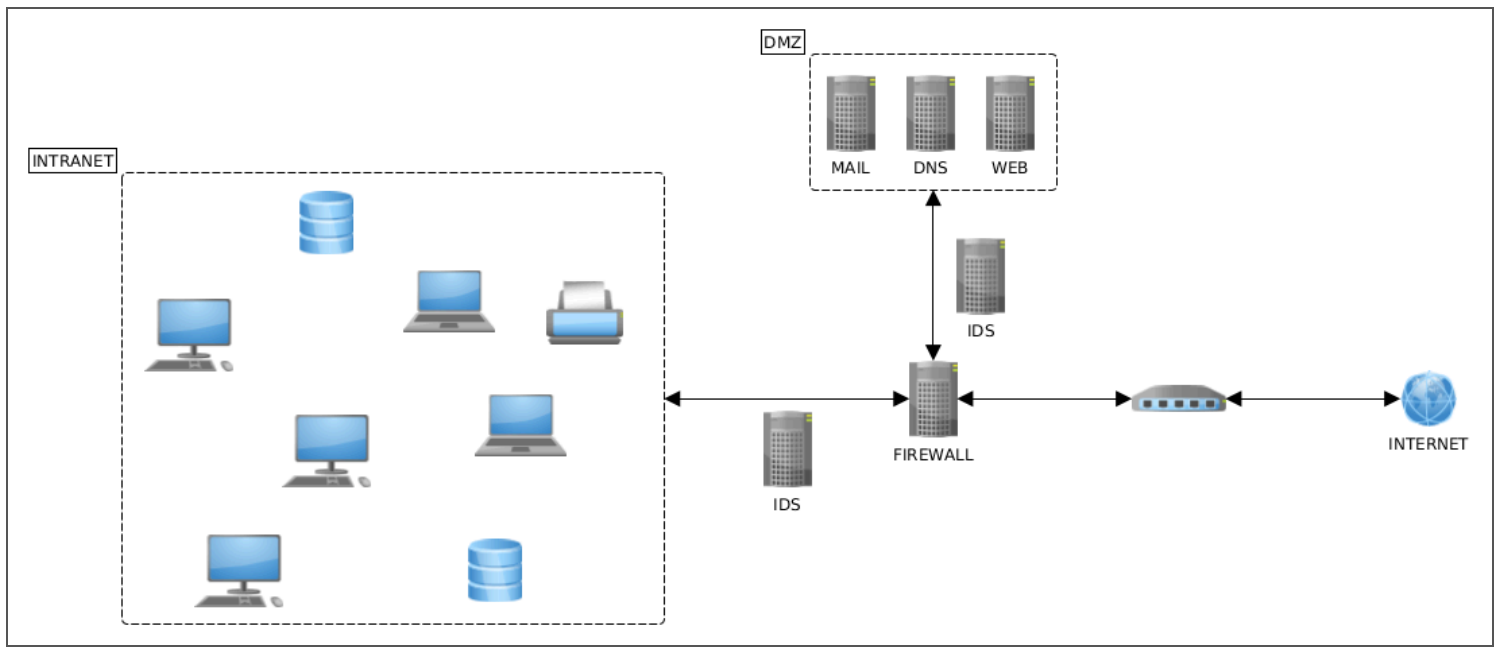
Host (HIPS, HIDS) edo Network (NIPS, NIDS)

IDS/IPS

Heuristika (Arauak): ezagutzen diren erasoak bakarrik. Positibo faltsu batzuk.

Anomaliak: portaera-profila. Eraso berriak. Positibo faltsu gehiago.

IDS/IPS



IDS/IPS

SNORT

Suricata

Suricata laborategia

Honeypots

"Amua" sistema, eraso diezaioten

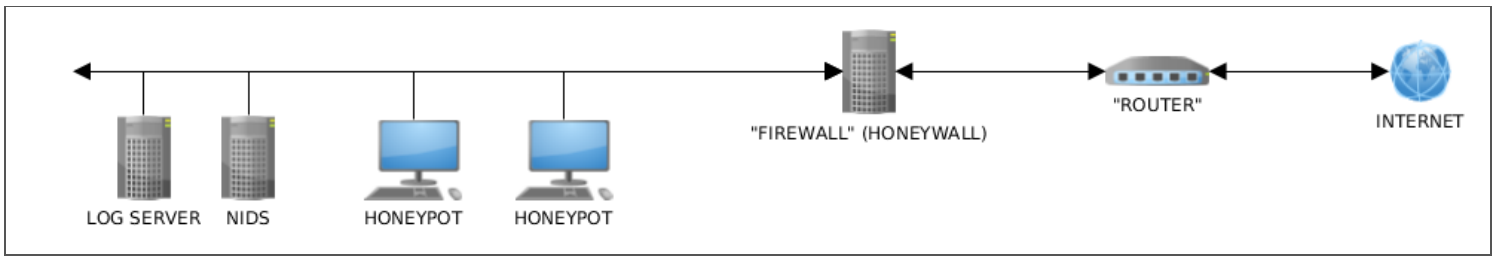
Honeynet: honeypot-en sarea

Erasoak desbideratu

Erasoei buruzko ezagutza lortzea

Malware-aren laginak lortzea

Honeypots


LOG SERVER
NIDS
HONEYPOT
HONEYPOT
"FIREWALL" (HONEYWALL)
"ROUTER"
INTERNET

Sare Birtual Pribatuak (VPN)

Segurua ez den azpiegitura (Internet) erabiltzen duen sarea, barne-sare batera modu seguruan sartzeko

Barne-sarera urrutitik konektatzeko erabiltzen dira

VPN EHU

Sare Birtual Pribatuak (VPN)

Honakoa ahalbidetzen du:

- Erabiltzaileak, rolak eta baimenak kudeatuz autentifikatzea eta baimentzea
- Osotasuna, hash funtzioen erabilerarekin
- Konfidentzialtasuna, informazioa enkriptazio-algoritmo baten bidez zifratuta doalako
- Zapuztezintasuna, datuak sinatuta transmititzen direlako

Log-en analisia: Common Log Format

```
127.0.0.1 user-identifier frank [10/Oct/2000:13:55:36 -0700]
                                "GET /apache_pb.gif HTTP/1.0" 200 2326
```

- Bezeroaren IPa
- Bezeroaren identifikazioa
- Erabiltzailearen autentikazio-izena
- Konexioaren data/ordua

Log-en analisia: Common Log Format

```
127.0.0.1 user-identifier frank [10/Oct/2000:13:55:36 -0700]
                                "GET /apache_pb.gif HTTP/1.0" 200 2326
```

- Bezeroaren eskaera
- Itzulitako HTTP egoera
- Bidalitako byte-ak

Eraso ohikoenak

Sniffing: Sarean zehar doan informazioa atzematea

Man in the middle: Informazioa atzemateaz gain, nahieran txertatu eta alda daiteke

Eraso ohikoenak

Hijacking: Sisteman autentifikatutako erabiltzaile bati konexioak lapurtzea

- IP Hijacking
- Session hijacking
- DNS Hijacking
- ...

Eraso ohikoenak

Spoofing (Nortasun-ordezkapena)

- IP Spoofing
- MAC Spoofing
- DNS Spoofing
- ...

Eraso ohikoenak

Zerbitzuaren Ukapena (DoS): Hardwarea edo softwarea "saturatu" egiten da erantzuteari utzi arte

Zerbitzuaren Ukapen Banatua (DDoS):

- Hainbat makinatatik egiten da
- Horietako batek master lanak egiten ditu eta gainerakoak koordinatzen ditu

Eraso ohikoenak

Zerbitzuaren Ukapen Banatua (DDoS):

GitLab servers are being exploited in DDoS attacks in excess of 1 Tbps

Google mitigated the largest DDoS attack to date, peaking above 398 million rps